PROTEXXA CYBER NATIONS SCOTIARISE CYBER SECURITY ANALYST PROGRAM ASSIGNMENT 7: VULNERABILITY MANAGEMENT

VULNERABILITY MANAGEMENT



REPORT BASED ON THE GROUP 7 SCAN RESULTS

Zolian R. Smith
August 24 2025

Introduction

Vulnerability Management (VM) is a continuous process of identifying, classifying, prioritizing, remediating, and mitigating security vulnerabilities in software, hardware, and network environments. It is a critical aspect of an organization's cybersecurity strategy designed to ensure that potential weaknesses are addressed before they can be exploited by malicious actors.

This report analyzes the Tenable vulnerability scan results for systems 10.13.30.105 and 10.13.30.242, conducted on January 5, 2024, focusing on identifying high, medium, and low severity vulnerabilities and providing appropriate remediation strategies.

Vulnerability Analysis

The following details outline the key characteristics of 3 vulnerabilities identified in the scan results:

Vulnerability 1: SSL Medium Strength Cipher Suites Supported (SWEET32)

1. **Plugin ID**: 42873
2. **Severity**: Medium (CVSS v3.0 Base Score: 7.5)
3. **Affected System**: 10.13.30.242 (TCP/3389)
4. **Vulnerability State**: Active
5. **CVE Reference**: CVE-2016-2183

6. **Description**: The remote host supports the use of SSL ciphers that offer medium strength encryption, specifically 3DES encryption which is vulnerable to SWEET32 attacks

7. **Impact**: Easier circumvention of medium strength encryption, especially if attacker is on the same physical network

8. **Discovery Method**: SSL/TLS cipher enumeration

9. **Publication Date**: November 23, 2009

10. **Modification Date**: February 3, 2021

Remediations

- **Remediation 1**: Disable 3DES cipher suites (DES-CBC3-SHA) in the SSL/TLS configuration

- **Remediation 2**: Configure the system to only support strong cipher suites with key lengths >= 112 bits

- **Remediation 3**: Update SSL/TLS configuration to prefer AEAD ciphers like AES-GCM over CBC mode ciphers

Vulnerability 2: TLS Version 1.0 Protocol Detection

1. **Plugin ID**: 104743

2. **Severity**: Medium (CVSS v3.0 Base Score: 6.5)

3. **Affected System**: 10.13.30.242 (TCP/3389)

4. **Vulnerability State**: Active

5. **CWE Reference**: CWE-327 (Use of a Broken or Risky Cryptographic Algorithm)
6. **Description**: The remote service accepts connections encrypted using TLS 1.0, which has cryptographic design flaws
7. **Impact**: Potential for cryptographic attacks due to known weaknesses in TLS 1.0 protocol
8. **Compliance Issue**: PCI DSS v3.2 requires TLS 1.0 to be disabled entirely by June 30, 2018
9. **Publication Date**: November 22, 2017
10. **Industry Standard**: Major web browsers no longer support TLS 1.0 as of March 31, 2020

Remediations

- **Remediation 1**: Disable TLS 1.0 support in the system's SSL/TLS configuration
- **Remediation 2**: Enable and enforce TLS 1.2 and TLS 1.3 as the minimum supported versions
- **Remediation 3**: Test applications and services to ensure compatibility with newer TLS versions before implementation

Vulnerability 3: Terminal Services Doesn't Use Network Level Authentication (NLA) Only

1. **Plugin ID**: 58453
2. **Severity**: Medium (CVSS v3.0 Base Score: 4.0)

3. **Affected System**: 10.13.30.242 (TCP/3389)
4. **Vulnerability State**: Active
5. **Service**: Remote Desktop Protocol (RDP)
6. **Description**: Terminal Services is not configured to use Network Level Authentication only, making it vulnerable to man-in-the-middle attacks
7. **Impact**: Potential for credential theft and unauthorized access through man-in-the-middle attacks
8. **Authentication Method**: Currently allows non-NLA security negotiations
9. **Publication Date**: March 23, 2012
10. **Protocol Used**: CredSSP (Credential Security Support Provider) when NLA is properly configured

Remediations

- **Remediation 1**: Enable Network Level Authentication (NLA) in the Remote Desktop settings through the 'Remote' tab of 'System' properties
- **Remediation 2**: Configure Group Policy to enforce NLA requirement for all RDP connections across the domain
- **Remediation 3**: Implement additional access controls such as VPN requirements or IP restrictions for RDP access

Additional Findings

Low Severity Issues Identified:

- **SSL Self-Signed Certificate**: The system uses a self-signed certificate (CN=EC2AMAZ-12G20RM) which nullifies SSL security benefits
- **SSL Certificate Common Name Mismatch**: Certificate CN doesn't match the hostname, potentially enabling man-in-the-middle attacks
- **TLS Version 1.1 Support**: Deprecated protocol version that lacks support for current cipher suites

Recommendations

1. **Immediate Actions**: Disable weak SSL/TLS protocols and cipher suites, enable NLA for RDP services
2. **Certificate Management**: Implement proper SSL certificate management with trusted Certificate Authority
3. **Regular Scanning**: Establish continuous vulnerability scanning schedule to identify new threats
4. **Patch Management**: Develop systematic approach to applying security updates and patches
5. **Access Controls**: Implement principle of least privilege and network segmentation for critical services

Conclusion

The vulnerability assessment reveals multiple medium-severity security issues primarily related to cryptographic implementations and remote access configurations. While no critical vulnerabilities were identified, the cumulative risk from these medium-severity issues could provide attack vectors for malicious actors. Implementing the recommended remediations will significantly improve the security posture of the analyzed systems.